SPIKA TECH™

POLÍTICA DE CONTINUIDAD DE NEGOCIO

HISTORIAL DEL DOCUMENTO			
Versión	**Resumen de modificaciones**	**Fecha de entrada**	**Sustituye a (Código, revisión)**
01	Primera versión del documento.	26/02/2025	N/A

REGISTRO DE FIRMAS			
Función:	**Elaborado por:**	**Revisado por:**	**Aprobado por:**
Departamento:	Responsable del SGSI	Dirección	Jefe de seguridad (o suplente)
Nombre:	David Pozo	Carlos Rodrigo	Carlos Zúñiga
Firma:	Firmado por POZO SANCHEZ DAVID - ***6992** el día 26/02/2025	Firmado por RODRIGO RIVERO, CARLOS (AUTENTICACIÓN) el día 26/02/2025	Firmado por ***8264** CARLOS ZUÑIGA (R: ****8690*) el día 26/02/2025 con un
Fecha:	26/02/2025	26/02/2025	26/02/2025

CONTENIDO

1 OBJETIVO 3
2 ALCANCE 4
3 NORMATIVA APLICABLE 4
4 MISIÓN Y VISIÓN DE SPIKA TECH 4
5 DESARROLLO DE LA POLÍTICA 4
5.1 PRINCIPIOS INTEGRADORES 5
5.2 REQUISITOS MÍNIMOS DE SEGURIDAD 7
5.3 OBJETIVOS DE LA POLÍTICA 9
5.4 REVISIÓN DE LA POLÍTICA 10
6 MARCO NORMATIVO 10
7 ORGANIZACIÓN DE LA SEGURIDAD 10
8 GESTIÓN DEL RIESGO 11
9 OBLIGACIONES DEL PERSONAL 11
10 AUDITORÍA 11
11 GARANTIZACIÓN DE CONTINUIDAD 12
11.1 ESTUDIO INICIAL Y ANÁLISIS DE IMPACTO DE NEGOCIO (BIA). 13
11.2 GESTIÓN DE CRISIS: ESCENARIOS DE DESASTRE Y ESTRATEGIAS DE CONTINUIDAD 14
11.3 PLAN DE CONTINUIDAD Y RECUPERACIÓN DE DESASTRES 14
12 CONOCIMIENTO DEL PERSONAL DE SPIKA TECH 14
13 REGISTROS Y ARCHIVOS 15
14 REFERENCIAS 15

1 OBJETIVO

El presente documento complementa y desarrolla la Política de Seguridad de la Información de SPIKA TECH para recoger los aspectos particulares con la continuidad de los servicios y procesos específicos que se llevan a cabo dentro del área TI de la propia organización, así como recoger los requisitos determinados que son exigidos por las distintas normas y regulaciones que le afectan

2 ALCANCE

Esta Política de seguridad TIC es de aplicación, con carácter obligatorio, sobre todos los sistemas TIC responsabilidad de SPIKA TECH, servicios y procesos de negocio, activos de información y sus dependencias, personal interno o externo que tenga acceso información o sistemas de SPIKA TECH (con independencia de que exista o no una relación de carácter laboral) y, cualquier otra entidad involucrada con SPIKA TECH en la utilización de su información y sus sistemas.

3 NORMATIVA APLICABLE

Es aplicable toda la normativa establecida en el documento de **RGS_1 NORMATIVA APLICABLE.xlsx.**, que se actualizara de forma periódica Las Políticas, Normas y Procedimientos dentro del alcance del SGSI, se actualizarán, si procede, en base a los cambios normativos que pudieran afectar.

4 MISIÓN Y VISIÓN DE SPIKA TECH

El Área de TI de SPIKA TECH es el área dentro de la organización que tiene como principal función la coordinación y el impulso de la estrategia sobre Tecnologías de la Información (TI) y de la transformación digital.

Para ello, entendemos como prioridad la creación de un sistema de gestión de la información que se encuentre alineado con los principales estándares en relación con seguridad de la información.

5 DESARROLLO DE LA POLÍTICA

SPIKA TECH sustenta la mayoría de sus actividades de servicios y procesos en Sistemas de Información, siendo estos un soporte básico para la operativa interna, la gestión de los servicios que proporciona y su desarrollo organizacional.

La información manejada por los diferentes sistemas y aplicaciones, así como la infraestructura de comunicaciones, constituyen, junto a las personas, el activo principal para el normal desarrollo de las operaciones realizadas. Con este fin ha desarrollado esta Política de Continuidad de servicio que está constituida por la estructura organizativa, los recursos

humanos y técnicos, los procesos, planes, procedimientos y protocolos relacionados con las medidas de prevención y respuesta frente a los riesgos de seguridad de naturaleza física, lógica y el cumplimento de la regulación normativa, aplicable y del buen gobierno corporativo. Los requisitos y objetivos de seguridad de la información y continuidad de los servicios, son determinados en base a los criterios derivados de las políticas, normas y las necesidades dadas por los responsables de los activos de información y de los procesos de SPIKA TECH, siendo su alcance todas las actividades relacionadas con la seguridad de la información y continuidad de las operaciones, con especial enfoque en la seguridad lógica.

Su aplicabilidad abarca la prestación de aquellas actividades y servicios que son prestados directamente por SPIKA TECH, así como por terceros que sigan las directrices e instrucciones de la propia organización.

5.1 PRINCIPIOS INTEGRADORES

Sin perjuicio de los principios básicos establecidos en la Política de Seguridad de la Información otras normas de rango superior, esta política se desarrollará, con carácter general, de acuerdo a los principios enumerados a continuación que fundamentan su necesidad, naturaleza y cuyo establecimiento evidencia el liderazgo y el compromiso de SPIKA TECH respecto del sistema de gestión de la seguridad de la información y continuidad de servicio:

a) **Principio de confidencialidad:** los sistemas de información deberán ser accesibles únicamente para aquellas personas usuarias, órganos y entidades o procesos expresamente autorizados para ello, con respeto a las obligaciones de secreto y sigilo profesional.

b) **Principio de integridad y calidad:** se deberá garantizar el mantenimiento de la integridad y calidad de la información, así como de los procesos de tratamiento de la misma, estableciéndose los mecanismos para asegurar que los procesos de creación, tratamiento, almacenamiento y distribución de la información contribuyen a preservar su exactitud y corrección.

c) **Principio de disponibilidad y continuidad:** se garantizará un nivel de disponibilidad en los sistemas de información y se dotarán los planes y medidas necesarias para asegurar la continuidad de los servicios y la recuperación ante posibles contingencias graves.

d) **Principio de Seguridad Integral:** se entenderá la seguridad como un proceso integral que incluya a todos los elementos técnicos, humanos, materiales y organizativos de los sistemas de información.

e) **Principio de gestión del riesgo:** se deberá articular un proceso continuo de análisis y tratamiento de riesgos como mecanismo básico sobre el que debe descansar la gestión de la seguridad de los sistemas de información.

f) **Principio de proporcionalidad en coste:** la implantación de medidas que mitiguen los riesgos de seguridad de los sistemas de información deberá hacerse bajo un enfoque de proporcionalidad en los costes económicos y operativos, sin perjuicio de que se asegurará que los recursos necesarios para el sistema de gestión de seguridad de la información estén disponibles.

g) **Principio de concienciación y formación:** se articularán iniciativas que permitan a las personas usuarias conocer sus deberes y obligaciones en cuanto al tratamiento seguro de la información. De igual forma, se fomentará la formación específica en materia de seguridad de las tecnologías de la información de todas aquellas personas que gestionan y administran sistemas de información y telecomunicaciones.

h) **Principio de prevención:** se desarrollarán planes y líneas de trabajo específicas orientadas a prevenir fraudes, incumplimientos o incidentes relacionados con la seguridad de las tecnologías de la información.

i) **Principio de detección y respuesta:** los servicios deben monitorizar la operación de manera continua para detectar anomalías en los niveles de prestación de los servicios y actuar en consecuencia respondiendo eficazmente, a través de los mecanismos establecidos al efecto, a los incidentes de seguridad. Existirán mecanismos de recuperación que permitan la restauración y recuperación de la información y de los servicios para que en el caso de un incidente de seguridad que inhabilite los servicios y sistemas, éstos puedan restablecerse.

j) **Principio de Líneas de defensa:** Se establecerá una estrategia que se componga de varias capas de seguridad, para que en el caso de que una de las capas falle, se dote al sistema de capacidad para ganar tiempo para reaccionar, de reducir las probabilidades de que se comprometa dicho sistema, así como de que, si es afectado, se pueda minimizar el impacto.

k) **Principio de mejora continua y reevaluación periódica**: se revisará el grado de cumplimiento de los objetivos de mejora de la seguridad planificados anualmente y el grado de eficacia de los controles y medidas de seguridad de las tecnologías de la información implantados, al objeto de reevaluarlos y actualizarlos a la constante evolución de los riesgos y del entorno tecnológico, llegando a replantear la seguridad si se da el caso.

l) **Principio de seguridad de las tecnologías de la información en el ciclo de vida de los sistemas de información:** las especificaciones de seguridad se incluirán en todas las fases del ciclo de vida de los servicios y sistemas, acompañadas de los correspondientes procedimientos de control.

5.2 REQUISITOS MÍNIMOS DE SEGURIDAD

Esta Política identifica y consagra los requisitos de seguridad del SGSI a desarrollar en el marco normativo.

A continuación, se describen los requisitos del SGSI:

- Que identifique a los **responsables de la Organización e implantación del proceso de seguridad**, por el que se compromete a todos los miembros de la organización a tomar parte en la Seguridad, de modo que, todos conocerán la política.
- Que tenga en cuenta los **criterios que determinan el nivel de seguridad** requerido del SGSI, como resultado de la valoración y categorización de este.
- Que considere el **Análisis y Gestión de los Riesgos** mediante una metodología reconocida que mitigue o elimine las situaciones potencialmente peligrosas, justificando y ponderando las medidas en función de los riesgos.
- Mediante la **Gestión de personal**, con la publicación y divulgación de normas y procedimientos para que todo el personal esté al tanto de sus deberes y obligaciones referentes a la seguridad y se supervise que éstas se cumplan, teniendo especial consideración en llevar un control a través de un sistema de identificación de usuarios que identifique y trace quien tiene derechos de acceso o quien ha realizado alguna actividad.
- Que el personal que atienda, revise y audite la seguridad, sea determinado con criterios de **Profesionalidad** acordes a las tareas que se realizan y con la debida

formación. La organización se asegurará de que su personal reciba la formación adecuada para sus funciones que garantice la seguridad de las tecnologías de la información que se relacionan con los sistemas.

- **Autorización y control de los accesos**, donde el acceso al sistema de información deberá ser controlado y limitado a los usuarios, procesos, dispositivos y otros sistemas de información, debidamente autorizados, restringiendo el acceso a las funciones permitidas.
- **Protección de las instalaciones**, donde los sistemas se instalarán en áreas separadas, dotadas de un procedimiento de control de acceso.
- En la **adquisición de productos de seguridad de las tecnologías de la información y comunicaciones** que vayan a ser empleados se utilizarán, de forma proporcionada a la categoría del sistema y nivel de seguridad determinados, aquellos que tengan **certificada la funcionalidad de seguridad relacionada con el objeto de su adquisición**, salvo en aquellos casos en que las exigencias de proporcionalidad en cuanto a los riesgos asumidos no lo justifiquen a juicio del responsable de Seguridad.
- Los sistemas deben diseñarse y configurarse de forma que garanticen la seguridad por defecto.
- **Integridad y actualización del sistema.** Por el que se conocerá en todo momento el estado de seguridad de los sistemas, en relación a las especificaciones de los fabricantes, a las vulnerabilidades y a las actualizaciones que les afecten, reaccionando con diligencia para gestionar el riesgo a la vista del estado de seguridad de los mismos.
- **Protección de la información almacenada y en tránsito.** Para ello se aplicarán las medidas que correspondan a la naturaleza del soporte en que se encuentren, de conformidad con las normas de aplicación a la seguridad de los mismos.
- **Prevención ante otros sistemas de información interconectados**, donde se harán una especial atención a las conexiones a la res redes.
- **Registro de actividad de los usuarios**, reteniendo la información necesaria para monitorizar, analizar, investigar y documentar actividades indebidas o no autorizadas, permitiendo identificar en cada momento a la persona que actúa.

- **Incidentes de seguridad.** Se establecerá un sistema de detección y reacción frente a código dañino, así como los procedimientos de gestión de incidentes de seguridad y de debilidades detectadas en los elementos del sistema de información.
- **Continuidad de la actividad**. Se dispondrán de copias de seguridad y establecerán los mecanismos necesarios para garantizar la continuidad de las operaciones, en caso de pérdida de los medios habituales de trabajo.

5.3 OBJETIVOS DE LA POLÍTICA

Esta Política establece el marco necesario para alcanzar la máxima eficiencia y las mejores prácticas que se desarrollarán por medio de normativa de seguridad que aborde aspectos específicos coordinando estas actividades y servicios, persiguiendo en todo caso los siguientes objetivos:

- Evitar e impedir, en la medida de lo posible, cualquier situación de riesgo que pueda interrumpir o limitar el continuo y correcto funcionamiento de la actividad SPIKA TECH en caso de producirse dicha situación, minimizar y restablecer la normalidad funcional con la mayor rapidez posible mejorando la resiliencia.
- Desarrollar un modelo eficaz basado en un Sistema de Gestión de Seguridad de la Información y continuidad de servicio creado sobre normas nacionales e internacionales y capaces de operar con indicadores de desempeño y cumplimiento.
- Lograr un nivel de seguridad óptimo y a la vez económicamente viable para SPIKA TECH. Es responsabilidad de la organización en su ámbito de actuación, promover y apoyar la implantación de las medidas técnicas y organizativas necesarias para minimizar los riesgos potenciales a los que se encuentra expuesta la información y los procesos operativos, dentro de su alcance, en la consecución de los objetivos estratégicos y tácticos de la organización.

Es responsabilidad de la organización su ámbito de actuación, promover y apoyar la implantación de las medidas técnicas y organizativas necesarias para minimizar los riesgos potenciales a los que se encuentra expuesta la información y los procesos operativos, dentro de su alcance, en la consecución de los objetivos estratégicos y tácticos de la organización.

5.4 REVISIÓN DE LA POLÍTICA

La revisión anual de esta Política de Continuidad de Servicio, así como la propuesta de modificación o mantenimiento de esta, le corresponde a la Dirección de SPIKA TECH.

La revisión de esta Política será aprobada por la Dirección de SPIKA TECH y convenientemente difundida para que la conozcan todas las partes afectadas.

6 MARCO NORMATIVO

La identificación de las leyes, normativas y regulaciones que son aplicables a las actividades de SPIKA TECH para las distintas áreas de la organización y que afectan a la seguridad de la información, es un requisito fundamental para alcanzar sus objetivos, siendo una actividad que debe desarrollarse de forma continuada, para poder recoger todos los cambios que puedan producirse y las distintas necesidades que se deriven.

Por tanto, desarrollará los procedimientos adecuados con los que identificar y aplicar los requisitos legales, normativos, regulatorios y contractuales que puedan afectar a la gestión y operación de sus servicios. La relación completa de leyes, normativas, regulaciones y otras obligaciones contractuales identificadas para cada sistema de gestión de la Seguridad de la Información implantado, se podrán consultar en el documento **RGS_1 NORMATIVA APLICABLE.**

7 ORGANIZACIÓN DE LA SEGURIDAD

El mantenimiento y gestión de la seguridad de los Sistemas de Información va íntimamente ligada al establecimiento de una estructura organizativa que promueva y supervise la aplicación de los objetivos de seguridad fijados, establece su estructura mediante la identificación y definición de diferentes funciones y responsabilidades en materia de gestión de la seguridad de los sistemas de información y de la continuidad de las operaciones, que la soporte. La estructura y funcionamiento de la organización de la seguridad de los Sistemas de Información queda detallada en el **Procedimiento de roles y segregación de funciones.**

8 GESTIÓN DEL RIESGO

La gestión de riesgos debe realizarse de manera continua sobre los sistemas de información, conforme a los principios de gestión de la seguridad basada en los riesgos y reevaluación periódica.

El Responsable del SGSI junto con sus personas delegadas, son los encargados de realizar los preceptivos análisis de riesgos y de seleccionar las salvaguardas a implantar, siguiendo las pautas de la metodología para el análisis y gestión de riesgos implantada y que es descrita en el documento **Procedimiento de análisis y gestión de riesgos.**

El Responsable de la Información son los responsables de los riesgos sobre la información y sobre el servicio, respectivamente, y por tanto de aceptar los riesgos residuales calculados en el análisis y de realizar su seguimiento y control sin perjuicio de la posibilidad de delegar esta función. El proceso de gestión de riesgos, que comprende las fases de categorización de los sistemas, análisis de riesgos y selección de medidas de seguridad a aplicar, que deberán ser proporcionales a los riesgos y estar justificadas, deberá revisarse una vez al año de forma ordinaria y de manera extraordinaria, cuando se produzcan cambios en la información, en los servicios, ocurran incidentes significativos de seguridad o sean identificadas vulnerabilidades graves.

9 OBLIGACIONES DEL PERSONAL

Todos los usuarios de SPIKA TECH que, de forma directa o indirecta, accedan o hagan uso de los servicios de Ciberseguridad que estén sustentados por el SGSI tienen la obligación de conocer y cumplir esta norma de Continuidad de Servicio, así como la normativa que la desarrolle, siendo responsabilidad de, disponer los medios necesarios para que la información llegue a todos.

El incumplimiento manifiesto de la Política continuidad de Servicio o la normativa y procedimientos derivados de ésta, podrá acarrear el inicio de las medidas disciplinarias oportunas y, en su caso, las responsabilidades legales correspondientes.

10 AUDITORÍA

El SGSI será objeto de una auditoría regular ordinaria, interna y externa, que verifique el cumplimiento de los requerimientos de cada una de las normas que dan cumplimiento, según

lo establecido en los requisitos de los propios esquemas de gestión. Asimismo, con carácter extraordinario, deberá realizarse dicha auditoría siempre que se lleven a cabo modificaciones sustanciales en los sistemas de información que puedan repercutir en el cumplimiento de las medidas de seguridad requeridas.

Los informes de auditoría serán utilizados como medida del desempeño de la operación y mantenimiento del SGSI para su mejora continua.

11 GARANTIZACIÓN DE CONTINUIDAD

Debido a la importancia de los servicios que se realizan por parte de la organización y a la necesidad de resiliencia ante posibles desastres, se llevarán a cabo las siguientes actividades que permitan garantizar la operativa y funcionamiento correcto dentro del órgano.

El alcance de los procedimientos y guías desarrolladas para garantizar la continuidad de los servicios deberán comprender:

- Las actividades operativas que se desarrollen en las diferentes áreas funcionales dentro de SPIKA TECH.
- Se encontrarán dentro del análisis y revisión las instalaciones, infraestructuras, personas, información, sistemas y proveedores que den soportes a estos procesos y actividades.
- Se obtendrá un modelo funcional que establezca las fases de activación, los equipos involucrados y las acciones a seguir para garantizar la continuidad de los servicios esenciales y el cumplimiento de tiempos óptimos de recuperación.

Para garantizar el servicio será de vital importancia implementar soluciones de continuidad y recuperación, desarrollar y aprobar los planes, así como garantizar el mantenimiento y vigencia permanente. En este sentido, el desarrollo de estos planes:

- Servirá para minimizar el período de interrupción de los procesos, servicios y/o actividades afectadas.
- Servirá para minimizar las repercusiones para la propia actividad interna y externa de SPIKA TECH, derivada de la falta de determinados servicios, especialmente se cuidará la cadena de suministro y proveedores.

- Se minimizarán las pérdidas financieras y de valor, juntamente con posibles pérdidas reputacionales.
- Se desarrollarán estratégicas de alineamiento y coordinación de respuestas a crisis donde se incluyan servicios de alerta temprana, gestión y notificación de eventos e incidentes de seguridad, donde se garantice el cumplimiento legal de todas las actuaciones llevas a cabo durante el ciclo de vida de gestión de la crisis.

11.1 ESTUDIO INICIAL Y ANÁLISIS DE IMPACTO DE NEGOCIO (BIA).

Se realizará un estudio pormenorizado respecto a la madurez en cuanto seguridad física y lógica de SPIKA TECH, se incluirán aspectos como: documentación y estrategias desarrolladas, niveles de madurez, contexto, tamaño, tipología de servicio, requisitos legales, etc.

Se tendrán entrevista con los responsables de las principales áreas dentro de SPIKA TECH.

Para llevar a cabo el desarrollo del BIA, se deberá tener en cuenta:

- Identificación de las actividades/ procesos que soportan los servicios de la Organización.
- Selección de niveles de impacto, para cada ámbito, en función del tiempo.
    - Identificación de recursos y dependencias para cada una de las actividades (proveedores, información, interdependencias, horarios, personal etc.).
    - Valoración de criticidad de actividades y establecimiento de umbrales óptimos de recuperación.
    - Determinación del período de tiempo máximo para operar tras la interrupción (MTDP) y periodos de recuperación en función de la criticidad (RTO y RPO).
    - Identificación de recursos críticos TIC vitales para generar prioridades en caso de interrupción.

Por último, durante esta fase, se plasmará toda la información del BIA en registros donde se plasmarán todas las necesidades del servicio.

11.2 GESTIÓN DE CRISIS: ESCENARIOS DE DESASTRE Y ESTRATEGIAS DE CONTINUIDAD

Con la información estratégica obtenida del BIA y el Análisis de Riesgos desarrollado para dar cumplimiento a la ISO 27001:2022, se desarrollará una matriz de escenarios de desastre y estrategias de recuperación para aquellos activos que sean críticos y esenciales dentro de SPIKA TECH.

Entre los escenarios de desastre se podrán encontrar: imposibilidad de acceso físico al puesto de trabajo, ausencia de personal clave, ataques de denegación de servicio, error o fallo en sistemas de información, etc.

Entre las estrategias de recuperación, se podrán encontrar: desplazamientos a localización alternativa, activación de sistemas de Respaldo, decisiones de equipo de gestión de crisis, etc.

11.3 PLAN DE CONTINUIDAD Y RECUPERACIÓN DE DESASTRES

Una vez desarrollados los escenarios de desastre y estrategias de recuperación se desarrollarán los planes de continuidad y los planes de recuperación de sistemas principales o críticos afectados. En estos planes se contemplarán aspectos como: análisis de la información de los equipos de respuesta ante el impacto del incidente, desarrollo de estrategias adecuadas, responsables del documento y mantenimiento, roles y funciones dentro de SPIKA TECH, medios alternativos y tiempos de activación, estrategias predefinidas para para los posibles escenarios, puntos de contacto y canales de comunicación, proceso de escalado, etc.

Una vez desarrollados estados planes será necesario implementar un conjunto de medidas destinadas a la disminución del nivel de riesgo actual y, medidas orientadas a implementar estrategias y soluciones de continuidad y recuperación.

12 CONOCIMIENTO DEL PERSONAL DE SPIKA TECH

El conocimiento, observancia y respeto de la presente Política es vinculante todos los usuarios de SPIKA TECH vinculados al SGSI de la organización y terceras partes, cuando de forma

directa o indirecta, accedan o hagan uso de los servicios de Ciberseguridad que estén sustentados por dicho SGSI.

13 REGISTROS Y ARCHIVOS

	Nombre del registro	Versión y Modificaciones
REGISTRO	**N/A**	N/A

14 REFERENCIAS

- ISO 27001:2022:
  - 5.29 Seguridad de la información durante la interrupción.
  - 5.30 Preparación para las TIC para la continuidad del negocio.